Security Requirements Document

Web-Based ML Model Evaluator

1. Introduction

1.1 Purpose

This document consolidates security requirements for the Web-Based ML Model Evaluator. It covers user accounts, uploaded datasets, experiment runs, evaluation results, downloadable artifacts, and the administrative functions defined in the SRS.

1.2 Source documents

- Software Requirements Specification, v1.0: FR-1.1 to FR-7.4 and NFR-3 to NFR-14.
- Use Case Flow Document, v1.0: UC-01 to UC-14.
- Use Case Diagram, v1.0: actors and role boundaries.
- Test Plan Document, v1.0: functional, access-control, validation, and integrity test cases.

1.3 How to read the requirements

Each security requirement has a stable SEC ID, a requirement statement, a source reference, and a basis. “Stated” means the requirement is directly supported by the SRS or use-case scope. “Derived” means it adds security detail that the project team should confirm before treating it as a release commitment.

2. System Context

2.1 Assets to protect

Asset	Why it matters
User accounts and credentials	Access to protected functions depends on them.
Uploaded datasets and metadata	They may contain private information and must remain associated with the correct owner.
Experiment configurations and run history	They explain how results were produced and must not be altered or exposed to unrelated users.
Evaluation metrics and visualizations	They are used to interpret and compare model performance.
Model artifacts and reports	Unauthorized or incorrect downloads can expose data or return the wrong run's output.
Application configuration and logs	Secrets and internal details must not be exposed.

3. Threat Overview

Threat	Addressed by
Credential guessing or unauthorized account use	SEC-AUTH-1 to SEC-AUTH-4; SEC-SES-1 to SEC-SES-3
Accessing another user's datasets, runs, or artifacts	SEC-AZ-1 to SEC-AZ-5; SEC-DAT-1 to SEC-DAT-4
Malformed uploads and invalid experiment configuration	SEC-INP-1 to SEC-INP-3
Tampering with run metadata or returning the wrong artifact	SEC-DAT-2 to SEC-DAT-4
Sensitive details exposed through errors or logs	SEC-AUD-1 to SEC-AUD-2; SEC-OPS-1
Unauthorized administrative or Instructor actions	SEC-AZ-3 to SEC-AZ-6

4. Security Requirements

4.1 Authentication

ID	Requirement	Source	Basis
SEC-AUTH-1	All dataset, run-history, training, evaluation, and download operations shall require an authenticated user; anonymous access shall be limited to public entry points such as registration and login.	FR-1.2, FR-1.4	Stated
SEC-AUTH-2	Passwords shall not be stored in plaintext. The application shall use an appropriate password-storage mechanism and shall not return passwords in API responses or logs.	NFR-3	Stated at high level; implementation detail to confirm
SEC-AUTH-3	Failed login attempts shall return a generic error that does not reveal whether an account exists.	FR-1.2, NFR-13	Derived
SEC-AUTH-4	Repeated failed login attempts should be rate-limited or otherwise protected	NFR-3, NFR-11	Derived

	according to a policy selected for the deployment.		

4.2 Session Management

ID	Requirement	Source	Basis
SEC-SES-1	Session identifiers or authentication tokens shall be generated securely and validated by the backend for protected requests.	FR-1.2, NFR-3	Derived
SEC-SES-2	The application shall document its session-expiry policy; expired sessions shall not access protected resources.	FR-1.3, NFR-3	Derived
SEC-SES-3	Logout shall invalidate or terminate the active session so it cannot be reused for protected access.	FR-1.3	Stated

4.3 Authorization

ID	Requirement	Source	Basis
SEC-AZ-1	Authorization shall be enforced server-side for every protected endpoint; hiding a control in the UI shall not be treated as sufficient protection.	FR-1.4, NFR-4	Stated
SEC-AZ-2	A user shall access only datasets, runs, metrics, and artifacts they own or are explicitly authorized to review.	FR-2.5, FR-6.1, NFR-5	Stated
SEC-AZ-3	Only an authenticated Admin shall access user-management functions. Regular users and Instructors shall be denied access through the UI and direct API requests.	FR-7.1	Derived from stated role scope
SEC-AZ-4	Only an authenticated Admin shall access administrative dataset-management functions; operations shall preserve dataset ownership and run associations.	FR-7.2, FR-2.5, NFR-12	Derived from stated role scope
SEC-AZ-5	Instructor access shall be read-only and limited to evaluation results explicitly made available for review.	FR-7.4, FR-5.1, FR-5.2	Stated
SEC-AZ-6	Only an authenticated Admin shall view the administrative system-log interface and its underlying endpoints.	FR-7.3	Derived from stated role scope

4.4 Audit and Accountability

ID	Requirement	Source	Basis
SEC-AUD-1	The application shall record available relevant activity events, such as dataset uploads, training outcomes, and administrative actions, without logging passwords, tokens, or raw dataset contents.	FR-7.3, NFR-13	Derived
SEC-AUD-2	The system-log view shall be read-only through the application and shall not expose secrets or sensitive internal configuration.	FR-7.3, NFR-13	Stated at high level; details derived

4.5 Data Protection and Integrity

ID	Requirement	Source	Basis
SEC-DAT-1	Uploaded datasets, run history, metrics, and artifacts shall not be exposed to another user through lists, direct identifiers, or download endpoints.	FR-2.5, FR-6.1, NFR-5	Stated
SEC-DAT-2	A failed upload, preprocessing operation, training run, or export shall not corrupt previously completed runs or unrelated user data.	FR-4.3, FR-6.1, NFR-6	Stated
SEC-DAT-3	Dataset metadata, configuration, metrics, and artifact references shall remain associated with the correct user and run.	FR-4.3, FR-5.4, NFR-12	Stated
SEC-DAT-4	Each downloaded model artifact or report shall correspond to the selected authorized run.	FR-5.4, NFR-12	Derived

4.6 Input Handling

ID	Requirement	Source	Basis
SEC-INP-1	The backend shall validate user-controlled input, including uploaded file structure, dataset identifiers, target columns, preprocessing options, split values, algorithm selections, and export requests.	FR-2.2, FR-3.1 to FR-3.3, FR-4.1, FR-5.4	Stated

SEC-INP-2	Database access shall use safe query mechanisms, and user-provided values shall not be interpreted as database commands.	NFR-10, NFR-13	Derived
SEC-INP-3	User-controlled text and error details shall be rendered or returned safely; stack traces, secrets, and internal filesystem paths shall not be exposed.	NFR-13	Stated at high level; implementation detail derived

4.7 Application and Operations

ID	Requirement	Source	Basis
SEC-OPS-1	Passwords, API keys, and other secrets shall not be committed to source control or exposed in frontend bundles, logs, or API responses.	NFR-3, NFR-13, NFR-14	Derived
SEC-OPS-2	Dependencies shall be declared and the team shall have a documented way to review and update vulnerable dependencies.	NFR-10, NFR-14	Derived
SEC-OPS-3	Deployed environments handling credentials and uploaded data shall use HTTPS/TLS; local-development exceptions shall be documented.	NFR-3, NFR-14	Derived

5. Role Permission Matrix

Function	Student / User	Instructor	Admin	ML Service
Register / login	Yes	Yes, if account exists	Yes	No
Upload and replace own dataset	Yes	No, unless separately granted	Supported admin actions only	No
Configure and train model	Yes	No	No, unless separately granted	Executes training when invoked
View own run history/results	Yes	No, except authorized review results	Supported administrative view only	No
View evaluation results made available for review	No additional privilege	Yes, read-only	Supported administrative view only	No
Compare and download own available results	Yes	No, unless separately granted	Supported administrative view only	No
Manage user accounts	No	No	Yes	No
Manage dataset records	Own datasets only	No	Yes	No
View system activity logs	No	No	Yes, read-only	No

6. Verification and Traceability

Requirements	Existing Test Plan coverage
SEC-AUTH-1 to SEC-AUTH-4	FR-1.2-UT-1, FR-1.2-UT-2, FR-1.4-ST-1; rate-limit verification is required if SEC-AUTH-4 is approved.
SEC-SES-1 to SEC-SES-3	FR-1.3-ST-1 and FR-1.4-ST-1; session handling should also be reviewed.
SEC-AZ-1 to SEC-AZ-6	FR-1.4-ST-1, FR-1.4-ST-2, FR-7.1-ST-2, FR-7.2-ST-2, FR-7.3-ST-2, FR-7.4-ST-2.
SEC-AUD-1 to SEC-AUD-2	FR-7.3-ST-1 and FR-7.3-ST-2.
SEC-DAT-1 to SEC-DAT-4	FR-2.5-IT-1, FR-4.3-ST-2, FR-5.4-IT-1, FR-6.1-ST-2.
SEC-INP-1 to SEC-INP-3	FR-2.2-UT-1, FR-2.2-UT-2, FR-3.1-UT-2, FR-3.2-UT-2, FR-3.3-UT-2, FR-4.1-UT-2, FR-6.3-ST-1.
SEC-OPS-1 to SEC-OPS-3	Review source control, dependency declarations, error responses, and deployed transport configuration before release.

7. Open Issues and Assumptions

Topic	Issue
Administrative scope	Confirm user management, administrative dataset management, and system-log viewing are included in the delivered application.
Instructor access	Confirm how results are made available to an Instructor and whether this role exists in the implemented authentication model.
Password and session policy	Exact password hashing implementation, rate-limit thresholds, and session expiry values must be documented.
Upload/resource limits	Maximum CSV size, accepted encoding, and processing limits must be confirmed and tested.
Deployment security	HTTPS/TLS, secret management, dependency review, and logging controls depend on the actual deployment environment.
Requirement status	Derived controls are proposals until accepted by the team; tests should remain unexecuted until evidence is collected.